

BANCO DIGITAL ECUADOR

Reto Técnico - Arquitecto de Soluciones Tecnológicas

Propuesta de Arquitectura de Banca Digital sobre AWS

C4: Contexto, Contenedores y Componentes
Alta disponibilidad | Seguridad | DR | Integración | KYC/Biometría | Auditoría

Agosto de 2026

Resumen ejecutivo

La solución propuesta utiliza AWS como plataforma de infraestructura y servicios administrados, manteniendo al Core Bancario como sistema de registro financiero. El diseño prioriza seguridad, trazabilidad, baja latencia, desacoplamiento y recuperación ante fallas, evitando trasladar al cache o a servicios satélite decisiones financieras que deben permanecer bajo consistencia fuerte en el Core.

Decisión	Recomendación
Front-end	SPA en React + TypeScript y app móvil en React Native. Alternativa: Angular + Flutter.
Autenticación	Amazon Cognito con OIDC/OAuth 2.0 Authorization Code + PKCE. Después del onboarding, preferir passkeys WebAuthn con biometría local; contraseña + MFA como respaldo.
Onboarding/KYC	Amazon Rekognition Face Liveness + CompareFaces, orquestado por un servicio KYC. Complementar con proveedor externo para validación documental/AML cuando aplique.
Backend	API Gateway Regional -> VPC Link V2 -> ALB interno -> microservicios en Amazon ECS sobre AWS Fargate. Lambda para consumidores/eventos puntuales.
Transferencias	Step Functions Standard para la orquestación; idempotencia obligatoria; adaptadores al Core y red interbancaria; eventos de resultado para auditoría/notificación.
Persistencia de lectura	Patrón Cache-Aside con ElastiCache Serverless (Valkey) para datos frecuentes no críticos. Opcional CQRS/read model si el Core permite CDC.
Auditoría	DynamoDB append-only para consulta operativa + S3 Object Lock en modo WORM para evidencia inmutable.
Notificaciones	EventBridge + SQS/DLQ + dos canales como mínimo: SMS/push mediante SNS/AWS End User Messaging y email mediante SES. Adaptador de proveedor alterno para contingencia.
HA/DR	Multi-AZ en región primaria y Warm Standby en segunda región. Replicación de Cognito, DynamoDB Global Tables y S3 CRR; failover controlado por Route 53.
Seguridad	WAF, Shield Advanced, KMS, Secrets Manager, IAM least privilege, Security Hub, GuardDuty, Inspector, Macie, CloudTrail y Config centralizados.

Punto crítico: “baja latencia” no puede garantizarse solo dibujando una región. Se debe medir desde los enlaces/ISPs reales del banco y contra el Core. La arquitectura incorpora CloudFront y conectividad privada, pero la región primaria debe seleccionarse con pruebas de p50/p95/p99 y validación regulatoria. Al 13-ago-2026, la región AWS Chile continúa anunciada y no debe asumirse disponible [A1].

1. Alcance, supuestos y principios

1.1 Alcance funcional

- Consulta de datos básicos de cliente, productos y cuentas.
- Consulta de histórico de movimientos.
- Transferencias entre cuentas propias e interbancarias.
- Onboarding digital con validación facial/KYC.
- Autenticación para SPA y app móvil mediante OAuth 2.0/OIDC.
- Notificación de movimientos por al menos dos mecanismos.
- Auditoría de acciones del cliente y retención de evidencia.
- Integración con Core Bancario y sistema complementario.

1.2 Supuestos explícitos

- El Core Bancario y el sistema complementario permanecen como sistemas existentes y pueden residir on-premises o en un entorno privado; se accede mediante servicios/APIs y conectividad controlada.
- La plataforma digital no reemplaza el ledger del Core. Los saldos, límites y confirmación final de una transferencia se validan contra el sistema autoritativo.
- No se incluye procesamiento de tarjetas. Si posteriormente se almacenan/procesan datos de tarjetas, deberá agregarse el alcance PCI DSS.

- Los objetivos RTO/RPO y SLO indicados son propuestos para el ejercicio y deben ser aprobados por negocio, riesgo, continuidad y cumplimiento.
- La solución no constituye asesoría legal; la normativa debe validarse con asesoría jurídica y la Superintendencia de Bancos antes de producción.

1.3 Principios de arquitectura

Principio	Aplicación
Core como fuente de verdad	No autorizar transferencias con datos provenientes únicamente del cache.
Zero Trust / mínimo privilegio	Autenticación fuerte, autorización por scopes/roles y servicios privados sin IP pública.
Desacoplamiento	Eventos y colas para notificación, auditoría y trabajos no síncronos.
Idempotencia	Toda operación monetaria debe aceptar una clave idempotente y una referencia de negocio única.
Fail-safe	Timeouts, circuit breakers, reintentos con backoff y DLQ; no reintentar ciegamente efectos monetarios.
Observabilidad por diseño	Correlation ID, trazas, métricas y eventos de auditoría desde el primer release.
Privacy by design	Minimización de PII/biometría, retención explícita, cifrado y separación de funciones.
IaC	Infraestructura desplegada mediante CloudFormation/CDK; ambientes reproducibles y auditables.

2. Decisiones de solución y trazabilidad del reto

Requerimiento del reto	Solución AWS propuesta	Justificación
SPA + móvil multiplataforma	React/TypeScript + React Native; alternativa Angular + Flutter	Reuso de capacidades, integración con SDKs OIDC y buen soporte de biometría/nativo.
OAuth 2.0	Cognito User Pools, Authorization Code + PKCE	PKCE está recomendado para clientes públicos SPA/móvil y reduce riesgo de interceptación del authorization code [A2].
KYC/biometría	Rekognition Face Liveness + CompareFaces + proveedor KYC/AML desacoplado	Liveness verifica presencia física y CompareFaces permite comparar selfie contra documento [A3].
3 servicios iniciales	Profile, Movements, Transfers + Onboarding, Notification, Audit e Integration Adapters	Separa dominios y evita que la API se convierta en un monolito de integración.
Mínimo 2 notificaciones	SMS/push + email; fallback a segundo proveedor	Separación de canales y procesamiento asíncrono evita que una falla de mensajería bloquee la transferencia.
Auditoría	DynamoDB + S3 Object Lock	Consulta rápida + evidencia WORM no modificable durante retención [A4].
Clientes frecuentes	ElastiCache Valkey con Cache-Aside + TTL	Reduce latencia/carga al Core sin convertir el cache en fuente de verdad [A5].
Alta disponibilidad	Multi-AZ, servicios administrados, Fargate distribuido, colas y redundancia de conectividad	Elimina puntos únicos de falla dentro de una región.
DR	Warm Standby multi-región + Route 53; replicación de identidad/auditoría/objetos	Balancea RTO con costo; Cognito soporta réplica multi-región con limitaciones específicas [A6].

3. Modelo C4 - Nivel 1: Contexto

El sistema de banca digital se ubica entre los canales del cliente y los sistemas autoritativos del banco. La nube no debe esconder esta dependencia: la experiencia digital puede ser altamente disponible, pero las operaciones financieras seguirán condicionadas por la disponibilidad y consistencia del Core y de la red interbancaria.

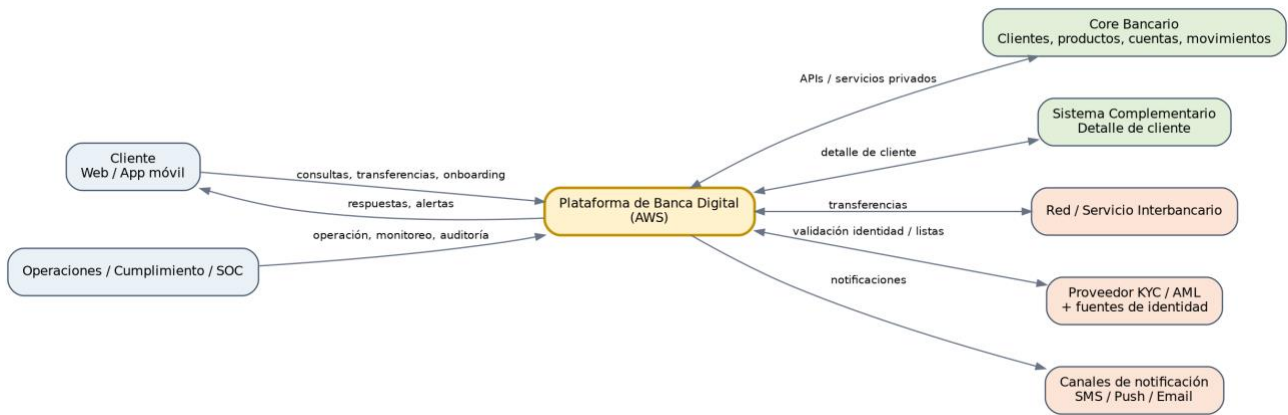


Figura 1. C4 - Diagrama de contexto del sistema de banca digital.

Actor/Sistema	Responsabilidad / interacción
Cliente	Onboarding, autenticación, consultas y transferencias desde SPA o app móvil.
Operaciones/Cumplimiento/SOC	Monitoreo, investigación, auditoría, respuesta a incidentes y evidencias.
Core Bancario	Fuente de verdad para cliente, productos, cuentas, saldos, movimientos y efectos monetarios.
Sistema complementario	Aporta detalle adicional del cliente cuando es requerido.
Servicio interbancario	Procesa/encamina transferencias hacia otras instituciones.
KYC/AML	Valida identidad, vivacidad, documento y controles de debida diligencia.
Notificaciones	Entrega confirmaciones/alertas por SMS, push y correo.

4. Modelo C4 - Nivel 2: Contenedores

Se usa una arquitectura de microservicios moderada: se separan dominios con razones claras de escalado, seguridad y ciclo de vida, sin crear decenas de servicios artificiales. El API Gateway conserva una fachada única hacia los canales.

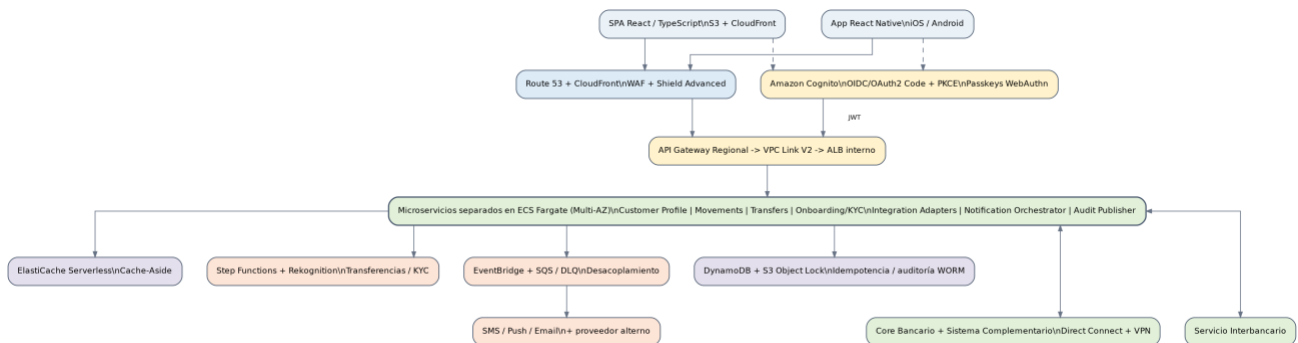


Figura 2. C4 - Contenedores principales y servicios AWS.

Contenedor	Tecnología	Responsabilidad
SPA	React/TypeScript, S3, CloudFront	Canal web; no almacena secretos; consume APIs con tokens OIDC.
App móvil	React Native	Canal iOS/Android; usa secure storage/keystore y passkeys del dispositivo.
Identidad	Amazon Cognito	Usuarios, tokens OIDC/OAuth2, passkeys WebAuthn, MFA y réplica multi-región.
API façade	Amazon API Gateway	Rutas, JWT validation, throttling, cuotas y observabilidad.
Microservicios	ECS Fargate + ALB interno	Profile, Movements, Transfers, Onboarding, Integration, Notification y Audit.
Event backbone	EventBridge + SQS/DLQ	Desacopla eventos de negocio, reintentos y consumidores.

Contenedor	Tecnología	Responsabilidad
Cache	ElastiCache Serverless Valkey	Cache-Aside de datos frecuentes no críticos y de lectura.
Stores	DynamoDB + S3 Object Lock	Idempotencia, auditoría operativa/read model y archivo inmutable.
Orquestación	Step Functions Standard	Flujo durable y auditable de transferencias; control de errores/reintentos.
Biometría	Amazon Rekognition	Face Liveness y comparación facial para onboarding/step-up selectivo.
Conectividad	Direct Connect + VPN	Acceso privado/redundante al Core y sistemas internos.

5. Modelo C4 - Nivel 3: Componentes

5.1 Componentes del servicio de Transferencias

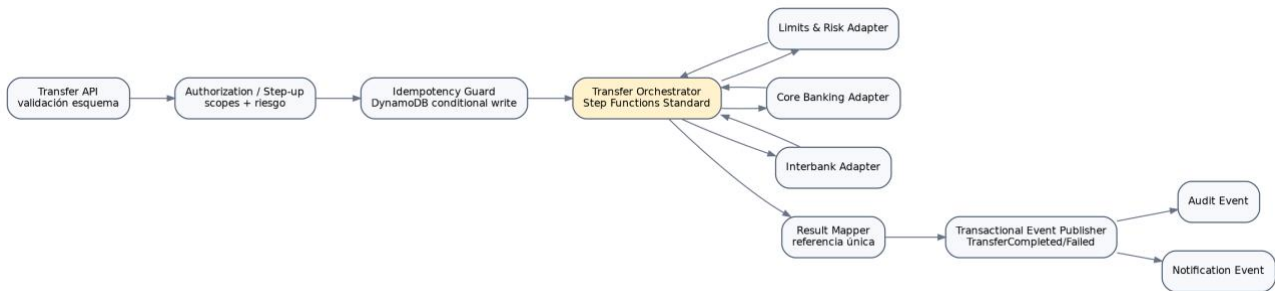


Figura 3. Componentes del dominio de transferencias.

La orquestación usa Step Functions Standard porque su modelo de ejecución es adecuado para acciones no idempotentes y workflows auditables [A7]. Sin embargo, esto no elimina la necesidad de idempotencia en el Core o en el proveedor interbancario: un timeout puede ocurrir después de que el sistema externo haya aplicado el débito. Por ello cada llamada monetaria debe llevar una referencia única y soportar consulta/reconciliación antes de reintentar.

Componente	Función	Control clave
Transfer API	Valida esquema y contexto de la solicitud.	No contiene lógica de negocio profunda; correlation ID obligatorio.
Authorization/Step-up	Valida scopes, propiedad de cuenta y si la operación requiere autenticación reforzada.	Paskey/MFA; políticas por monto/riesgo/dispositivo.
Idempotency Guard	Evita dobles solicitudes de la misma transferencia.	DynamoDB conditional write con idempotency key + TTL.
Orchestrator	Secuencia validaciones y ejecución.	Step Functions Standard, Retry/Catch selectivos, timeouts.
Core Adapter	Abstrae servicios del Core.	Timeout, circuit breaker, mTLS si es soportado.
Interbank Adapter	Abstrae proveedor/rail interbancario.	Referencia única, reconciliación y estado explícito.
Event Publisher	Publica TransferCompleted/Failed.	Publicación durable; auditoría y notificación desacopladas.

5.2 Componentes de Onboarding/KYC

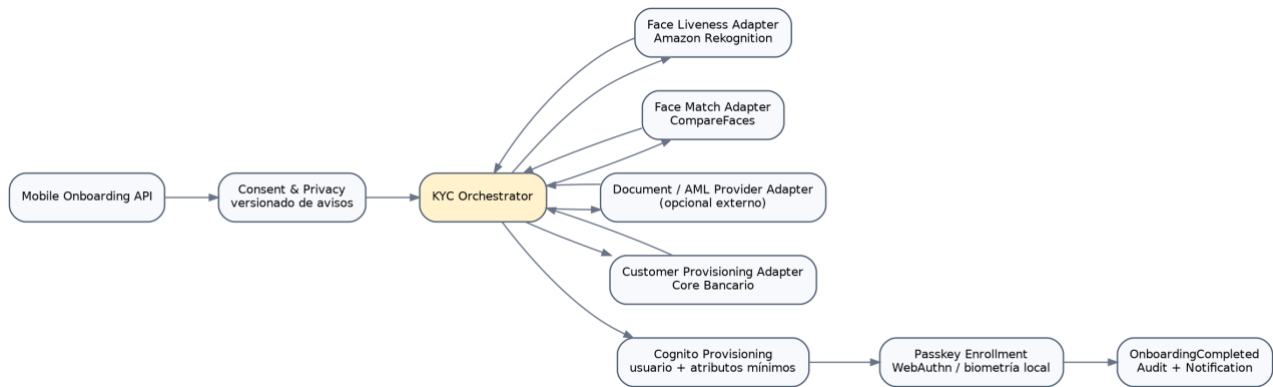


Figura 4. Componentes del dominio de onboarding y autenticación.

El onboarding facial y el login biométrico son problemas distintos. El primero valida identidad remota; el segundo debe usar preferentemente una passkey/WebAuthn cuya clave privada permanece protegida por el dispositivo. La huella o rostro usado para desbloquear la passkey no debe viajar a AWS ni almacenarse en Cognito.

Componente	Responsabilidad
Consent & Privacy	Versiona avisos de privacidad, consentimiento/base legitimadora y preferencias.
KYC Orchestrator	Coordina liveness, comparación facial, documento/AML y resultado de onboarding.
Rekognition adapters	Crea sesión de liveness y compara rostro con imagen de documento; almacena solo evidencia mínima requerida.
KYC/AML provider adapter	Permite sustituir proveedor externo sin afectar el canal móvil.
Core provisioning adapter	Crea/actualiza cliente en Core una vez superada la debida diligencia.
Cognito provisioning	Crea usuario con atributos mínimos; evita duplicar datos financieros en el IdP.
Passkey enrollment	Registra WebAuthn para acceso posterior resistente a phishing [A8].

6. Flujos principales

6.1 Autenticación recomendada

1. La SPA o app móvil genera code_verifier y code_challenge (PKCE) y redirige al endpoint de autorización de Cognito.
2. El usuario se autentica con passkey WebAuthn; como respaldo puede usarse contraseña + MFA. Para recuperación, usar un canal distinto al factor principal.
3. Cognito devuelve un authorization code; el cliente lo intercambia por ID/access/refresh tokens utilizando el code_verifier.
4. El cliente invoca API Gateway con access token. API Gateway valida JWT/scopes antes de enrutar al backend.
5. Para transferencias de mayor riesgo se ejecuta step-up authentication según políticas de monto, dispositivo o comportamiento.

Recomendación: no usar Implicit Flow ni guardar client secret en SPA/móvil. Authorization Code + PKCE es el patrón correcto para clientes públicos [A2].

6.2 Consulta de perfil y movimientos - Cache-Aside

6. Profile/Movements Service consulta ElastiCache con clave customer/account y versión de esquema.
7. Si hay cache hit y la información es apta para cache, responde con TTL/edad del dato.
8. Si hay cache miss, el Integration Adapter consulta Core y/o sistema complementario.
9. Se almacena una proyección mínima en cache con TTL corto y se responde al cliente.
10. Eventos relevantes del Core, si están disponibles, invalidan o actualizan el cache.

No cachear como autoridad: saldo disponible para autorización de una transferencia, bloqueos, límites críticos ni estados regulatorios sensibles. Para una pantalla informativa se podría mostrar un saldo cacheado solo si la UX indica su antigüedad y negocio lo acepta.

6.3 Transferencia

11. Cliente envía POST /transfers con idempotency-key, cuenta origen, destino, monto y metadata de dispositivo.
12. API Gateway valida token/scopes; Transfer Service valida propiedad de cuenta y decide si requiere step-up.
13. Idempotency Guard reserva la clave. Una repetición devuelve el resultado previo o el estado en curso, no ejecuta otra transferencia.
14. Step Functions Standard consulta Core para saldo/estado/límites y llama al rail apropiado (propia/interbancaria).
15. El resultado se confirma con referencia única y se persiste el estado de la solicitud.
16. Se publica TransferCompleted/Failed. Audit y Notification consumen el evento de forma independiente.
17. Ante estado incierto por timeout, el flujo entra en reconciliación/consulta de estado; no se reintenta el débito a ciegas.

6.4 Onboarding digital

18. Captura de aceptación de privacidad y términos con versión y timestamp.
19. Captura del documento y selfie/video guiado desde la app.
20. Backend crea una sesión de Face Liveness; Rekognition valida presencia real [A3].
21. Se compara el frame aprobado contra el rostro del documento. El umbral se define con riesgo/compliance y pruebas, no con un valor “por defecto”.
22. Proveedor KYC/AML ejecuta autenticidad documental, listas y controles requeridos por política.
23. Si el onboarding es aprobado, se crea/actualiza el cliente en Core y después la identidad digital en Cognito.
24. El usuario registra passkey WebAuthn; se emite evento de auditoría y notificación de alta.

7. Patrones de datos, persistencia y auditoría

7.1 Cache-Aside para clientes frecuentes

El patrón solicitado para persistencia de clientes frecuentes se implementa como Cache-Aside (lazy loading): el servicio busca primero en ElastiCache y solo ante ausencia consulta los sistemas autoritativos. AWS documenta Cache-Aside como una estrategia común de caché [A5].

Tipo de dato	¿Cache?	Política recomendada
Datos de perfil no críticos	Sí	TTL 5-30 min, invalidación por evento si existe.
Catálogos/productos	Sí	TTL más largo; versionado.
Histórico reciente de movimientos	Sí, con cautela	TTL corto o read model; no usar para conciliación contable.
Saldo disponible para autorizar transferencia	No	Leer del Core/fuente consistente en el flujo transaccional.
Credenciales/secretos	No	Secrets Manager / Cognito; jamás cache de aplicación.
Biometría cruda	Evitar	Minimizar y retener solo si existe base legal y plazo definido.

7.2 Opción de Read Model / CQRS

Si la latencia del Core impide una buena experiencia en consultas y el proveedor del Core permite CDC, se recomienda una segunda etapa con CQRS: la escritura permanece en el Core, mientras una proyección de solo lectura de movimientos/perfil se replica a AWS mediante CDC (por ejemplo AWS DMS hacia un destino apropiado) y se sirve desde DynamoDB/Aurora según el modelo de consulta. Esta opción requiere reglas claras de frescura y reconciliación; no se propone como requisito inicial porque el reto no confirma acceso CDC al Core.

7.3 Auditoría: consulta rápida + evidencia inmutable

Capa	Servicio	Uso
Auditoría de aplicación	DynamoDB	Eventos append-only: actor, action, resource, outcome, channel, device, IP, correlationId, timestamp, hash/reference. Evitar PII innecesaria.
Archivo inmutable	Amazon S3 Object Lock	WORM en Compliance mode para periodos aprobados; no puede sobrescribirse/eliminarse durante retención [A4].
Control plane AWS	AWS CloudTrail	Actividad de APIs AWS en cuentas; centralizado en Log Archive.

Capa	Servicio	Uso
Búsqueda/operación	CloudWatch Logs/OpenSearch opcional	Investigación rápida; no reemplaza el repositorio de evidencia.

8. Opciones de front-end y recomendación

Opción	SPA	Móvil	Ventajas	Desventajas	Decisión
1	React + TypeScript	React Native + TypeScript	Un lenguaje principal, ecosistema amplio, componentes/librerías compartibles, buen acceso a capacidades nativas y WebAuthn.	Requiere disciplina arquitectónica para evitar inconsistencia entre equipos.	RECOMENDADA
2	Angular + TypeScript	Flutter + Dart	Angular ofrece estructura enterprise fuerte; Flutter entrega UI consistente y buen rendimiento cross-platform.	Dos stacks/lenguajes; menos reuso de skills/código entre web y móvil.	Alternativa sólida

Selección: React + React Native favorece velocidad de entrega, unificación de skills y mantenimiento. La decisión final debe considerar las competencias reales del equipo; cambiar de stack solo por moda sería un error de arquitectura organizacional.

9. Infraestructura AWS propuesta



Figura 5. Vista de infraestructura AWS, conectividad híbrida y DR.

9.1 Landing zone / cuentas

- AWS Organizations / Control Tower con cuentas separadas: Production, NonProd, Security, Log Archive y Shared Services.
- SCPs para bloquear regiones no aprobadas, deshabilitar configuraciones inseguras y proteger logging/guardrails.
- CloudTrail organizacional, AWS Config y Security Hub delegados a la cuenta de seguridad.
- Break-glass role con MFA físico/passkey y procedimiento auditado.

9.2 Red y conectividad

- VPC regional desplegada en al menos tres Availability Zones para workloads críticos.
- ALB y tareas Fargate en subredes privadas; sin IP pública para microservicios.
- VPC endpoints para servicios AWS soportados; NAT solo para egress que realmente lo requiera.
- Conectividad al banco mediante Direct Connect redundante cuando el caso comercial/operativo lo justifique, con Site-to-Site VPN como respaldo; rutas y BGP diseñados para failover.
- Separar tráfico hacia Core, administración y terceros mediante controles de red y security groups por servicio.

9.3 Región y baja latencia

No fijaría una región solo por distancia geográfica. Se debe ejecutar un benchmark desde las sedes y proveedores de Internet del banco hacia las regiones candidatas, midiendo HTTPS y la ruta privada al Core. La región Chile está anunciada para finales de 2026, pero no debe usarse en un diseño “actual” hasta que aparezca como disponible en la infraestructura global de AWS [A1].

Métrica propuesta	Objetivo inicial	Comentario
p95 carga SPA estática	< 2 s	CloudFront y optimización front; medir desde Ecuador.
p95 API cache hit	< 300 ms	Objetivo de diseño, sujeto a región/ISP.
p95 consulta dependiente de Core	< 1.5 s	El Core y el enlace privado dominarán la latencia.
ACK de transferencia	< 1 s	No significa liquidación; puede retornar “processing” si el rail es asíncrono.
Disponibilidad plataforma digital	>= 99.99% objetivo	Debe medirse extremo a extremo incluyendo dependencias críticas.

10. Seguridad y monitoreo continuo

10.1 Controles preventivos

Capa	Controles
Edge	CloudFront, AWS WAF Managed Rules/rate limiting, Shield Advanced, TLS con ACM.
Identidad cliente	Cognito, passkeys WebAuthn, MFA/step-up, OAuth scopes, refresh token rotation según política, device/risk telemetry.
Identidad workforce	IAM Identity Center/federación corporativa, roles temporales, mínimo privilegio, separación de funciones.
Aplicación	Validación de entrada, OWASP ASVS/API Security, idempotencia, autorización por objeto, secretos fuera del código.
Datos	KMS customer-managed keys donde corresponda, TLS en tránsito, clasificación de PII, tokenización/enmascarado en logs.
Red	Subredes privadas, SG por servicio, endpoints privados, egress controlado; mTLS hacia sistemas que lo soporten.
Supply chain	ECR privado, Amazon Inspector para vulnerabilidades, IaC scanning y gates en CI/CD.

10.2 Detección y observabilidad

Servicio	Rol
CloudWatch	Métricas, logs, alarmas y dashboards técnicos/negocio.
AWS X-Ray / OpenTelemetry	Trazas distribuidas y correlación de latencia entre microservicios.
CloudTrail	Auditoría de API/control plane en AWS.
AWS Config	Cambios de configuración y reglas de cumplimiento.
GuardDuty	Detección de amenazas/anomalías en cuentas y workloads.
Security Hub	Agregación/priorización de hallazgos y controles de postura.
Inspector	Vulnerabilidades de contenedores/compute.
Macie	Descubrimiento de datos sensibles en S3 cuando aplique.
EventBridge	Automatización de respuesta y enrutamiento de incidentes.

10.3 Métricas de negocio imprescindibles

- LoginSuccess/Failure, MFA/Passkey challenge failure, account lockout y anomalías por dispositivo.
- TransferStarted/Completed/Failed/Unknown, tiempo de punta a punta y tasa de duplicados bloqueados por idempotencia.
- Latencia y errores por dependencia: Core, sistema complementario, interbancario, KYC, SMS y email.
- Delivery status de notificaciones por canal; DLQ depth y edad del mensaje más antiguo.
- Cache hit ratio, stale reads detectados e invalidaciones fallidas.

11. Alta disponibilidad y tolerancia a fallos

Riesgo	Diseño
Falla de una AZ	ECS Fargate distribuido en 3 AZ, ALB multi-AZ, servicios regionales administrados.
Pico de tráfico	Auto Scaling de ECS por CPU/memoria/request count; API throttling; EventBridge/SQS absorben picos asíncronos.
Core lento/no disponible	Timeouts, circuit breaker, bulkhead por dependencia; degradación controlada de consultas y bloqueo explícito de transferencias si no puede garantizarse consistencia.
Proveedor de notificaciones caído	Cola independiente por canal, reintentos, DLQ y proveedor alternativo; la transferencia no se revierte por falla de notificación.
Consumidor duplicado	Idempotencia en consumidores y claves de negocio; SQS puede redeliver.
Error de despliegue	Blue/green/canary, health checks, rollback automático e IaC versionada.
Corrupción/borrado	PITR/backup según servicio, S3 Object Lock, Backup Vault Lock para backups críticos [A9].

12. Recuperación ante desastres

Para una banca digital con presupuesto disponible, propongo Warm Standby multi-región: el entorno secundario mantiene componentes esenciales desplegados a menor escala y puede escalar durante un desastre. Es un punto medio entre Pilot Light y Active/Active, reduciendo complejidad operativa sin aceptar RTO de horas.

Componente	Estrategia DR	Objetivo propuesto
DNS/entrada	Route 53 failover health checks hacia stack regional secundario.	RTO 15-30 min incluyendo decisión operacional.
Cognito	Multi-Region user pool replication y custom domain/failover; revisar limitaciones de operaciones en réplica [A6].	RPO bajo; pruebas semestrales de failover.
DynamoDB	Global Tables para idempotencia/read model/audit operativo cuando sea apropiado [A10].	RPO segundos; resolución de conflictos diseñada.

Componente	Estrategia DR	Objetivo propuesto
S3 auditoría	Cross-Region Replication + Object Lock en destino.	RPO minutos según replicación; evidencia preservada.
ECS/API	IaC desplegada en región DR; servicios mínimos running y escalables.	RTO 15-30 min.
ElastiCache	No tratar cache como dato de DR; warm cache se reconstruye.	RPO no aplica.
Core on-prem	Conectividad redundante desde ambas regiones o sitios alternos del banco.	Depende del plan de continuidad del Core.
Backups	AWS Backup con políticas, copias cross-region y Vault Lock para recursos soportados.	RPO según clasificación del dato.

Prueba obligatoria: un DR que nunca se prueba es documentación, no una capacidad. Ejecutar game days, failover/failback y reconciliación de transferencias en estado incierto.

13. Diseño de notificaciones

La notificación se desacopla del flujo monetario. Una transferencia confirmada publica un evento; el Notification Orchestrator determina canales, prioridad y proveedor. Esto evita que una caída de email/SMS bloquee o duplique la transferencia.

Canal	AWS	Uso
Push móvil	Amazon SNS / servicio de mensajería móvil	Alertas inmediatas dentro de la app.
SMS	Amazon SNS integrado con AWS End User Messaging SMS	Canal externo al dispositivo/app para movimientos críticos [A11].
Email	Amazon SES	Comprobante/notificación con trazabilidad de entrega y manejo de bounces [A12].
Proveedor alternativo	Adapter HTTPS a segundo proveedor	Fallback por indisponibilidad, cobertura o restricciones locales. No acoplar el dominio al proveedor.

Para cumplir “mínimo 2”, la implementación base utiliza al menos SMS + email; push se agrega como tercer canal. El orden/fallback debe ser configurable por política y tipo de evento. Los mensajes no deben incluir saldos completos, números de cuenta completos ni PII innecesaria.

14. Elementos normativos y de cumplimiento

La arquitectura debe ser aprobada contra la normativa vigente del sistema financiero ecuatoriano y protección de datos. Los siguientes elementos son los mínimos a considerar en el diseño, no una lista exhaustiva:

Marco	Impacto arquitectónico
LOPDP - Ley Orgánica de Protección de Datos Personales [N1]	Base legitimadora, transparencia, derechos del titular, minimización, seguridad, privacidad desde el diseño/por defecto, transferencias internacionales y retención.
Reglamento General LOPDP - Decreto 904 [N2]	Desarrolla obligaciones de la LOPDP; refuerza evaluación de impacto, tratamiento y controles.
Datos biométricos / SPDP [N3]	Huella/imagen facial son datos biométricos sensibles/especiales; requieren legitimación, proporcionalidad, minimización y controles reforzados. Ejecutar DPIA para onboarding biométrico.
Superintendencia de Bancos - Codificación vigente, gestión de riesgo operativo [N4]	Gestión de riesgo tecnológico, seguridad de información/ciberseguridad, continuidad, terceros y evidencias de control.
Prevención de lavado de activos / UAFE [N5]	Debida diligencia “Conozca a su cliente”, monitoreo y controles AML; el KYC digital debe integrarse a procesos del oficial de cumplimiento.
Estándares de referencia	ISO 27001/27002, NIST CSF, CIS AWS Foundations, OWASP ASVS/API Security; ayudan a operacionalizar controles aunque no sustituyen regulación local.
PCI DSS - condicional	Solo si se incorpora procesamiento/almacenamiento/transmisión de datos de tarjetas.

14.1 Reglas de privacidad específicas para biometría

- No almacenar plantillas biométricas de huella/rostro del dispositivo para login; usar WebAuthn/passkeys.
- En onboarding, separar evidencia de KYC de datos operativos y aplicar retención explícita.
- Cifrar evidencia con KMS, restringir acceso por rol y registrar toda lectura administrativa.
- Evitar incluir imágenes faciales en logs/telemetría.
- Definir proceso de derechos del titular, eliminación cuando legalmente corresponda y legal hold cuando aplique.
- Documentar transferencias internacionales de datos a regiones/proveedores y el mecanismo legal correspondiente.

15. Operación, CI/CD y gobierno técnico

- Repositorios separados por dominio o monorepo con ownership explícito; trunk-based o GitFlow simplificado.
- Pipeline: build -> pruebas unitarias/contrato -> SAST/SCA -> imagen ECR -> Inspector -> despliegue no-prod -> integración -> aprobación -> blue/green prod.
- IaC con AWS CDK/CloudFormation; cambios de red, IAM y KMS requieren revisión adicional.
- Feature flags para separar despliegue de activación funcional.
- Runbooks para: Core unavailable, interbank timeout, Cognito failover, notification backlog, DLQ replay y DR regional.
- Tableros separados: negocio, SRE, seguridad y cumplimiento.

16. Riesgos, trade-offs y decisiones que no tomaría

Decisión / riesgo	Evaluación
Usar Lambda para todos los microservicios	No es mi primera elección para este caso. Fargate brinda control operacional y latencia más predecible en integraciones persistentes; Lambda sí es excelente para workers/eventos puntuales.
Active/Active completo desde el día 1	Aumenta conflictos, costo y complejidad. Warm Standby es mejor punto de partida salvo RTO/RPO regulatorios que exijan Active/Active.
Cachear saldos para autorizar transferencias	No. Optimiza UX, pero introduce riesgo de decisión con dato obsoleto.
Guardar biometría del dispositivo	No. Para login usar passkeys/WebAuthn; la biometría local desbloquea la clave en el dispositivo.
Reintentar automáticamente un POST de débito tras timeout	No sin reconciliación/idempotencia. Puede duplicar un efecto financiero.
Acoplar notificación a Transfer Service	No. Un fallo de SMS/email no debe fallar la transacción financiera.
Elegir la región "más cercana" sin medir	No. La topología de Internet y el enlace al Core dominan; se valida con datos.

17. Matriz final de cumplimiento del reto

Requisito	Cobertura en propuesta	Estado
Consulta histórico / transferencias	Movements Service + Transfer Service + adaptadores Core/interbank	Cubierto
Datos desde 2 sistemas	Integration Adapters al Core y sistema complementario	Cubierto
2 sistemas de notificación	SMS + email, push adicional y fallback por proveedor	Cubierto
SPA + móvil, 2 opciones	React/React Native; Angular/Flutter	Cubierto
OAuth 2.0 + mejor flow	OIDC/OAuth2 Authorization Code + PKCE	Cubierto
KYC + reconocimiento facial	Rekognition Face Liveness + CompareFaces + adapter KYC/AML	Cubierto
Login user/password, huella u otro	Passkey WebAuthn con biometría local + password/MFA respaldo	Cubierto
BD auditoría	DynamoDB + S3 Object Lock	Cubierto
Persistencia clientes frecuentes	Cache-Aside con ElastiCache; CQRS opcional	Cubierto
API Gateway + 3 servicios	API Gateway + Profile/Movements/Transfers + servicios adicionales	Cubierto
Normativa	LOPD/RGLOPD/SB/UAFE + controles de privacidad/ciberseguridad	Cubierto

Requisito	Cobertura en propuesta	Estado
HA/tolerancia a fallos	Multi-AZ, autoscaling, colas, circuit breakers, conectividad redundante	Cubierto
DR	Warm Standby multi-región, replicación y failover	Cubierto
Seguridad/monitoreo	WAF/Shield/KMS/Secrets + Security Hub/GuardDuty/CloudWatch/CloudTrail/Config	Cubierto
Escalabilidad/desacoplamiento	ECS Auto Scaling + EventBridge/SQS + dominios independientes	Cubierto
Baja latencia	CloudFront, cache, conexión privada; selección regional mediante benchmark	Cubierto con validación
C4 hasta componentes	Contexto, Contenedores, Componentes de Transfer y Onboarding	Cubierto

18. Conclusión

La arquitectura propuesta no intenta “modernizar” el Core por fuera del alcance. Construye una capa digital segura, resiliente y desacoplada alrededor de los sistemas autoritativos, con especial cuidado en los dos puntos que más riesgo introducen en banca digital: identidad y transferencias. La recomendación central es mantener consistencia financiera en el Core, usar AWS para elasticidad/experiencia digital, y diseñar todos los efectos externos con idempotencia, trazabilidad y mecanismos explícitos de recuperación.

Para una presentación técnica, defendería cinco decisiones: (1) Authorization Code + PKCE y passkeys; (2) Fargate para microservicios de integración y Lambda para workers; (3) Step Functions Standard + idempotencia para transferencias; (4) EventBridge/SQS para notificación/auditoría; y (5) Warm Standby multi-región con pruebas reales de DR.

Referencias oficiales consultadas

- [A1] AWS Global Infrastructure - Regions and Availability Zones. https://aws.amazon.com/about-aws/global-infrastructure/regions_az/
- [A2] Amazon Cognito - Using PKCE in authorization code grants. <https://docs.aws.amazon.com/cognito/latest/developerguide/using-pkce-in-authorization-code.html>
- [A3] Amazon Rekognition - Face Liveness / Identity Verification. <https://docs.aws.amazon.com/rekognition/latest/dg/face-liveness.html>
- [A4] Amazon S3 - Object Lock. <https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html>
- [A5] Amazon ElastiCache - Cache-aside pattern. <https://docs.aws.amazon.com/AmazonElastiCache/latest/dg/ecommerce-caching-valkey.html>
- [A6] Amazon Cognito - Multi-Region replication for user pools. <https://docs.aws.amazon.com/cognito/latest/developerguide/user-pool-multi-region.html>
- [A7] AWS Step Functions - Choosing workflow type. <https://docs.aws.amazon.com/step-functions/latest/dg/choosing-workflow-type.html>
- [A8] Amazon Cognito - Authentication flows / WebAuthn passkeys. <https://docs.aws.amazon.com/cognito/latest/developerguide/amazon-cognito-user-pools-authentication-flow-methods.html>
- [A9] AWS Backup - Vault Lock. <https://docs.aws.amazon.com/aws-backup/latest/devguide/vault-lock.html>
- [A10] Amazon DynamoDB - Global Tables. <https://docs.aws.amazon.com/amazondynamodb/latest/developerguide/GlobalTables.html>
- [A11] Amazon SNS - Mobile text messaging. <https://docs.aws.amazon.com/sns/latest/dg/sns-mobile-phone-number-as-subscriber.html>
- [A12] Amazon SES - Developer Guide. <https://docs.aws.amazon.com/ses/latest/dg/Welcome.html>
- [N1] Registro Oficial No. 459 - Ley Orgánica de Protección de Datos Personales. <https://www.registroficial.gob.ec/quinto-suplemento-al-registro-oficial-no-459/>
- [N2] Reglamento General LOPDP - Decreto Ejecutivo 904. <https://www.telecomunicaciones.gob.ec/wp-content/uploads/2023/11/Decreto-Ejecutivo-No.-904.pdf>
- [N3] Superintendencia de Protección de Datos Personales - Consultas sobre datos biométricos. <https://spdp.gob.ec/consultasatendidas/>
- [N4] Superintendencia de Bancos - Codificación de Normas, Libro Uno. <https://www.superbancos.gob.ec/bancos/codificacion-de-normas-de-la-sb-libro-uno-sistema-financiero/>
- [N5] UAFE - Glosario / Debida Diligencia. <https://www.uafe.gob.ec/glosario-de-terminos/>

Fuente del caso: “Reto Técnico Arquitecto Soluciones” - Banco Digital Ecuador, 2 páginas, proporcionado por el usuario.